

**ASIX PILDORAS:**

**DOCKER Y DOCKERHUB:**

**COMPROMETIENDO LA SEGURIDAD**

**DE DOCKER:**

**Parte Teórica**



**Integrantes:**

Bryan Canton

Nikolas Carmona

Alexandru Gabriel Babiac

Mukul Kumar Dadar

Alejandro Upegui Carvajal

Nadia Cayo Moya

Erec Dionisio Pereira

Muhammad Haris Ahmed Fatima

Guiu Ferrer Garcia

Frank Garcia Nebot

Hugo Castella

Alejandro Martinez

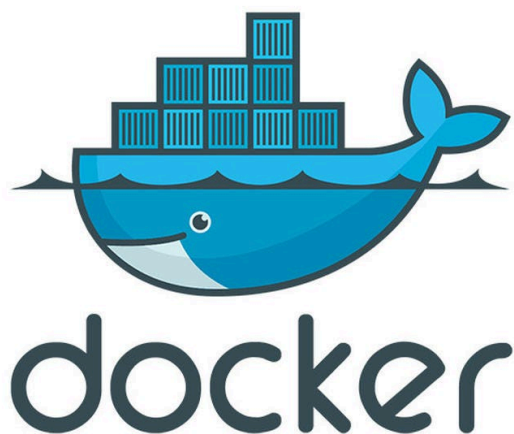
# ÍNDICE

|                                                                 |          |
|-----------------------------------------------------------------|----------|
| <b>Introducción a nuestra píldora de Ciberseguridad: Docker</b> | <b>4</b> |
| ¿Qué es Docker?                                                 | 4        |
| Principales características de Docker:                          | 5        |
| ¿Para qué sirve Docker?                                         | 6        |
| Comandos básicos de Docker                                      | 6        |
| Diferencias entre Docker y Máquinas Virtuales                   | 8        |
| Ataques Típicos a Docker                                        | 10       |
| 1. Imágenes Maliciosas                                          | 10       |
| 2. Escalada de Privilegios                                      | 11       |
| 3. Acceso No Autorizado a Registros de Imágenes                 | 11       |
| 4. Ataques de Denegación de Servicio (DoS)                      | 12       |
| 5. Fugas de Información (Data Exfiltration)                     | 12       |
| Ataque de Cadena: Nuestro Ataque                                | 13       |
| ¿Qué es y cómo funciona?                                        | 13       |
| Pasos del ataque:                                               | 13       |
| Métodos preventivos de ataques en cadena                        | 14       |
| Registro de Imágenes: ¿Qué es y cómo afecta a nuestro ataque?   | 15       |
| Conclusiones: ¿Qué hemos aprendido en este trabajo?             | 16       |
| Puntos clave aprendidos:                                        | 17       |

## Introducción a nuestra píldora de Ciberseguridad: Docker

En el mundo de la ciberseguridad, la contenedorización se ha convertido en una tecnología clave para el despliegue eficiente y seguro de aplicaciones. Sin embargo, como cualquier tecnología, no está exenta de riesgos. En esta píldora de ciberseguridad nos centraremos en Docker, una de las plataformas de contenedorización más utilizadas en la actualidad, y en los diferentes ataques a los que está expuesta.

Nuestro enfoque será práctico y didáctico, abordando tanto los conceptos básicos como los problemas y vulnerabilidades más comunes. Finalmente, presentaremos un ataque específico denominado Ataque en Cadena, explicando cómo funciona y cómo afecta a los registros de imágenes de Docker.

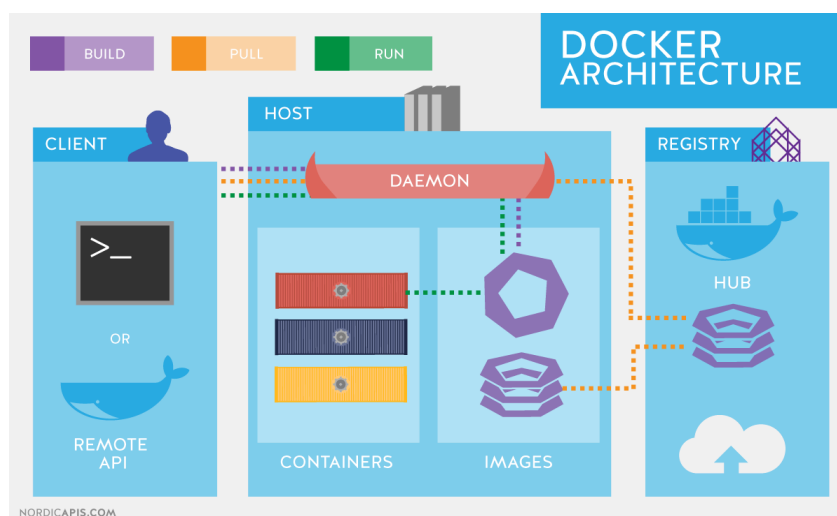


## ¿Qué es Docker?

Docker es una plataforma de software que permite desarrollar, empaquetar y ejecutar aplicaciones dentro de contenedores. Un contenedor es una unidad estandarizada de software que incluye todo lo necesario para que una aplicación se ejecute: código, bibliotecas, dependencias y configuraciones.

### Principales características de Docker:

- **Portabilidad:** Los contenedores pueden ejecutarse en cualquier entorno sin problemas de compatibilidad.
- **Eficiencia:** Al compartir el mismo kernel del sistema operativo, los contenedores consumen menos recursos que las máquinas virtuales.
- **Escalabilidad:** Facilita la creación y gestión de entornos de desarrollo y producción de manera ágil.
- **Automatización:** Permite definir el despliegue de aplicaciones mediante archivos de configuración.
- **Facilidad de uso:** Su sintaxis y estructura lo hacen accesible para desarrolladores y equipos de operaciones.



## ¿Cómo usar Docker?

Docker es una herramienta que nos permite crear, ejecutar y gestionar contenedores, que son entornos ligeros donde se pueden ejecutar aplicaciones de forma aislada y consistente, sin importar en qué sistema o máquina estemos. Esto lo hace perfecto para desarrolladores que desean que sus aplicaciones se comporten de la misma forma en cualquier entorno.

## ¿Para qué sirve Docker?

Docker facilita:

- **Portabilidad:** Puedes crear una aplicación y ejecutarla en cualquier máquina sin preocuparte por dependencias o configuraciones del sistema.
- **Aislamiento:** Cada contenedor es independiente, por lo que si un contenedor falla, no afecta a otros.
- **Escalabilidad:** Puedes desplegar aplicaciones fácilmente y aumentar la cantidad de contenedores según sea necesario.

## Comandos básicos de Docker

`docker --version`: Ver la versión de Docker instalada, también confirmar que docker esta en el sistema.

`docker pull <imagen>`: Descargar una imagen desde Docker Hub (un repositorio de imágenes públicas.)

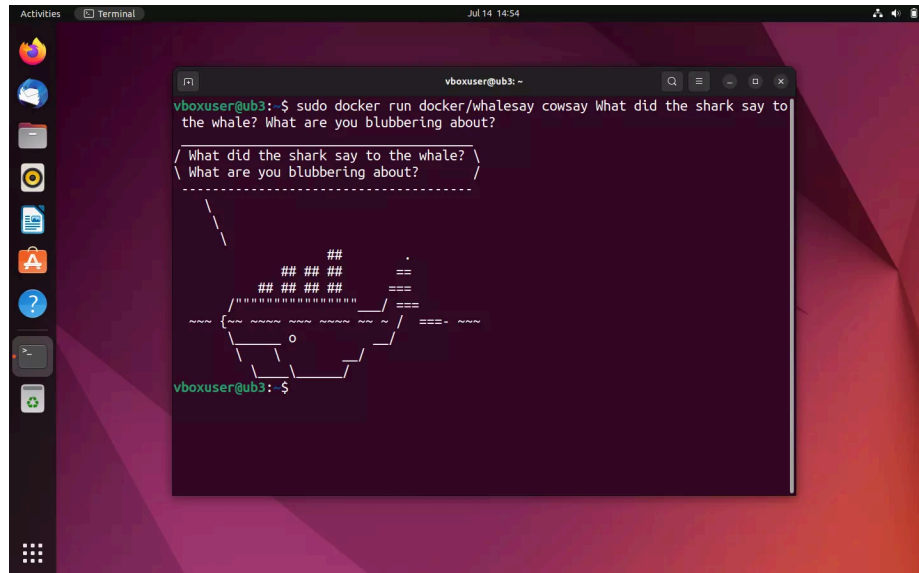
`docker run <imagen>`: Ejecutar un contenedor a partir de una imagen descargada.

`docker ps`: Ver los contenedores en ejecución.

`docker stop <id_del_contenedor>`: Detener un contenedor en ejecución.

`docker build -t <nombre_imagen> .`: Crear una imagen personalizada desde un Dockerfile.

`docker exec -it <id_contenedor> bash`: Acceder al terminal de un contenedor en ejecución.



## Que es DockerHub?

Docker Hub es un servicio en línea para almacenar y distribuir imágenes de contenedores, facilitando la gestión y despliegue de aplicaciones en entornos virtualizados.



### Características principales:

- Repositorio Centralizado: Espacio para almacenar imágenes de contenedores reutilizables.

- **Imágenes Oficiales:** Contiene imágenes de software popular, mantenidas por los desarrolladores.
- **Repositorios Públicos y Privados:** Los públicos son accesibles para cualquier usuario, y los privados requieren credenciales.
- **Automatización de Construcción de Imágenes:** Se puede integrar con repositorios para actualizar imágenes automáticamente.
- **Etiquetas (Tags):** Permiten identificar diferentes versiones de una imagen.
- **Webhooks:** Ejecutan acciones tras completar operaciones en el repositorio.
- **Autenticación y Gestión de Usuarios:** Permite controlar el acceso a imágenes, especialmente en repositorios privados.
- **Integración con Docker CLI y Docker Compose:** Se puede interactuar con Docker Hub mediante comandos.
- **Seguridad y Escaneo de Vulnerabilidades:** Ofrece escaneo de vulnerabilidades para mantener la seguridad.
- **Integración con Docker Desktop:** Facilita el uso de Docker Hub desde entornos locales.

**Beneficios:**

- **Facilidad en el Despliegue:** Ofrece imágenes listas para usar, simplificando el despliegue de aplicaciones.
- **Colaboración en Equipo:** Facilita compartir imágenes en equipos, con control de acceso.
- **Escalabilidad y Flexibilidad:** Las imágenes pueden usarse en cualquier máquina con Docker instalado.
- **Actualización Continua:** Mejora los flujos de trabajo mediante la automatización y la integración con CI/CD.

Docker Hub es clave en el ecosistema Docker, ofreciendo un repositorio accesible y seguro para gestionar imágenes de contenedores, ideal para desarrolladores que buscan eficiencia y escalabilidad.



 dockerhub

ExploreRepositoriesOrganizationsHelp

MDmdock

Filters (2) [Clear all](#)

Sort byRecently updated

1-25 of 46 available extensions

Products

☐ Images

☒ Extensions

☐ Plugins

Content

☒ Reviewed

☐ Not reviewed

 **Harpoon** • Reviewed • [VERIFIED PUBLISHER](#)

By Harpoon Corp • Updated 2 weeks ago

Docker Extension for the No Code Kubernetes platform.

Reviewed [19.0K](#)

Install

 **Grafana** • Reviewed • [VERIFIED PUBLISHER](#)

By Grafana Labs • Updated 1 month ago

Monitor your Docker Desktop instance from Grafana cloud.

Reviewed [19.0K](#)

Install

 **Tailscale** • Reviewed • [VERIFIED PUBLISHER](#)

By Tailscale Inc. • Updated 1 month ago

Tailscale lets you securely connect to your Docker containers without exposing them to the public internet.

Reviewed [10.0K](#)

Install

 **Snyk** • Reviewed • [VERIFIED PUBLISHER](#)

By Snyk Ltd. • Updated 2 months ago

Snyk Container extension enables you to scan your remote or local image and detect any contained vulnerabilities.

Reviewed [10.0K](#)

Install

 **Localstack** • Reviewed • [SPONSORED OSS](#)

By LocalStack GmbH • Updated 2 months ago

Extension of Localstack for Docker desktop

Reviewed [10.0K](#)

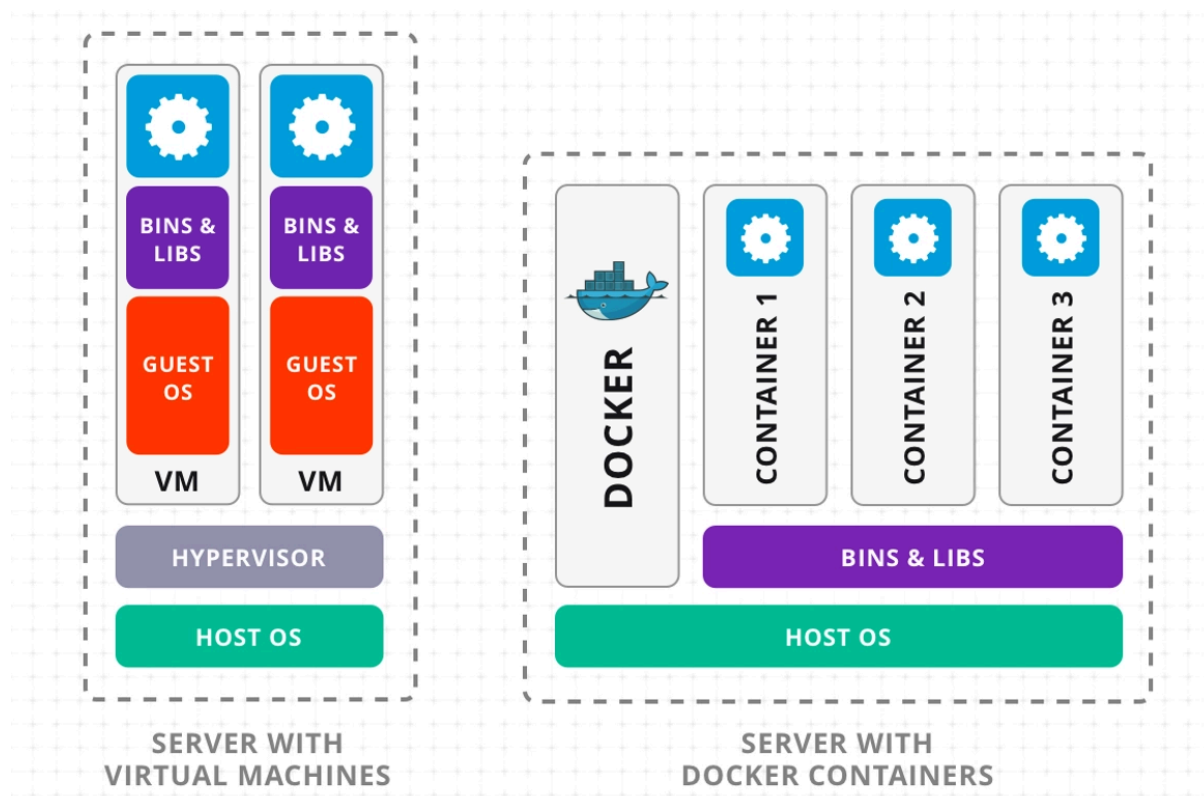
Install

## Diferencias entre Docker y Máquinas Virtuales

Aunque Docker y las máquinas virtuales (VMs) permiten ejecutar aplicaciones en entornos aislados, existen diferencias clave entre ambos:

| Característica      | Docker                                   | Máquina Virtual                         |
|---------------------|------------------------------------------|-----------------------------------------|
| Arquitectura        | Comparte el kernel del sistema anfitrión | Ejecuta un sistema operativo completo   |
| Consumo de recursos | Bajo, ya que no requiere SO adicional    | Alto, ya que cada VM tiene su propio SO |
| Tiempo de arranque  | Rápido                                   | Lento                                   |
| Aislamiento         | Menos seguro (comparte kernel)           | Más seguro (cada VM es independiente)   |
| Gestión de imágenes | Basado en capas y muy eficiente          | Pesado y consume más almacenamiento     |
| Mantenimiento       | Más sencillo y automatizable             | Requiere mayor intervención manual      |

En resumen, Docker es ideal para despliegues rápidos y eficientes en términos de recursos, mientras que las máquinas virtuales proporcionan un mayor aislamiento y seguridad a costa de un mayor consumo de recursos.



## La importancia de la seguridad en Docker

Docker se ha convertido en una tecnología esencial para el desarrollo y despliegue de aplicaciones. Sin embargo, su creciente adopción lo convierte en un objetivo atractivo para atacantes. Asegurar entornos Docker no solo protege los contenedores, sino también la infraestructura en la que operan.

Factores clave en la seguridad de Docker:

1. **Aislamiento de contenedores:** Docker comparte el kernel del sistema anfitrión, lo que hace que un fallo de seguridad pueda comprometer múltiples contenedores si no se establecen los controles adecuados.
2. **Imágenes seguras:** Descargar imágenes de fuentes no confiables puede introducir malware o vulnerabilidades.
3. **Gestión de credenciales:** Almacenar credenciales en contenedores es una mala práctica que puede facilitar accesos no autorizados.
4. **Configuraciones seguras:** La ejecución de contenedores con privilegios elevados representa un gran riesgo de seguridad.

Adoptar una mentalidad de seguridad desde la fase de desarrollo hasta el despliegue es clave para minimizar riesgos y garantizar la integridad de los sistemas.

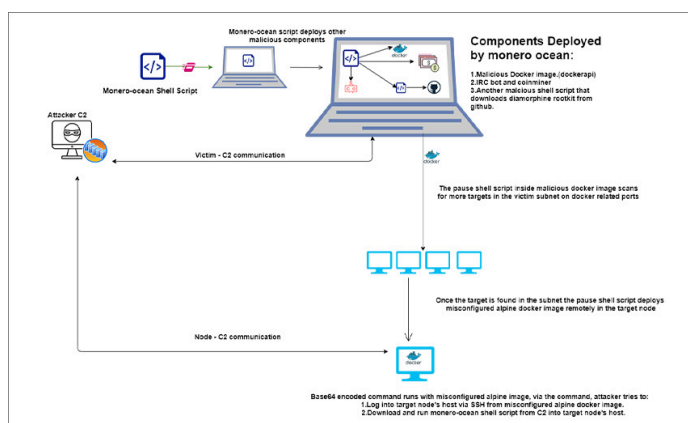
---

## Ataques Típicos a Docker

Docker es una herramienta muy potente y, como se ha mencionado anteriormente, suele ser bastante atacada. A continuación, exploramos algunos de los ataques más comunes que pueden afectar a los entornos Docker y cómo prevenirlos.

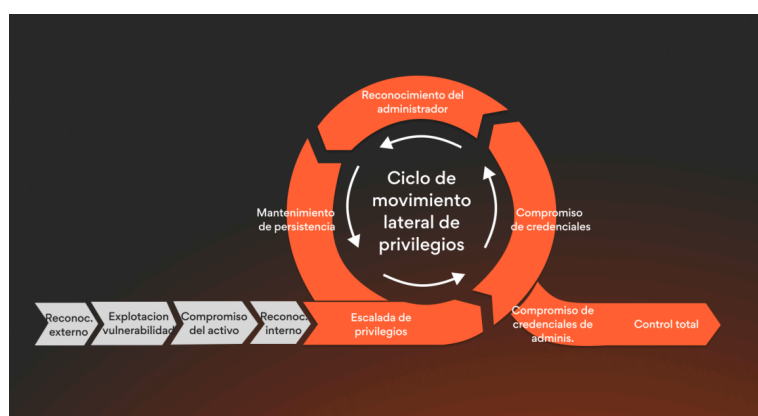
## 1. Imágenes Maliciosas

Los atacantes pueden cargar imágenes con malware o vulnerabilidades en repositorios, que luego se descargan por el usuario final, y al utilizarse se ejecutarán los archivos maliciosos.



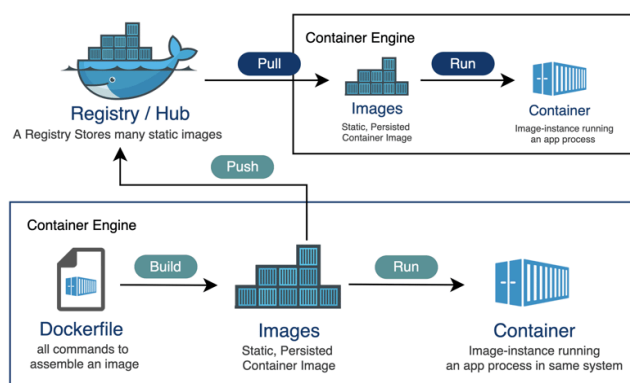
## 2. Escalada de Privilegios

Un atacante puede romper el aislamiento de un contenedor y acceder al sistema anfitrión, para ejecutar acciones maliciosas.



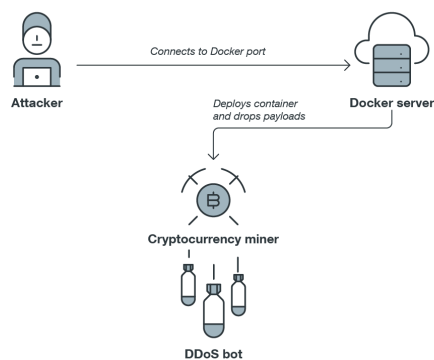
### 3. Acceso No Autorizado a Registros de Imágenes

Compromiso de registros de imágenes, afectando las aplicaciones al modificar o cargar imágenes maliciosas.



### 4. Ataques de Denegación de Servicio (DoS)

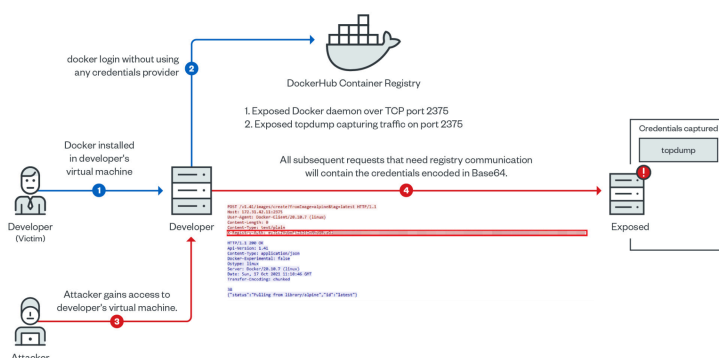
Sobrecarga de recursos del sistema o contenedor, dejándolos inoperativos.



## 5. Fugas de Información (Data Exfiltration)

Un atacante puede robar datos sensibles almacenados en un contenedor, exponiendo esta información a terceros.

- **Prevención:** No almacenar datos sensibles en contenedores, usar herramientas de gestión de secretos y cifrar volúmenes de datos.



## Ataque de Cadena: Nuestro Ataque

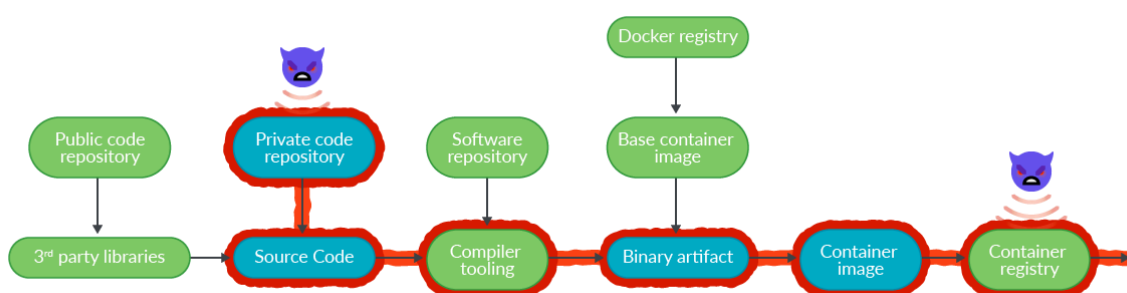
### ¿Qué es y cómo funciona?

El Ataque de Cadena en Docker es una estrategia en la que un atacante compromete un elemento de la infraestructura y, utilizando este acceso, logra comprometer otros componentes. Esto se consigue haciendo que el usuario se descargue una imagen de docker que ha sido modificada, por ejemplo: Si alguien quiere descargar Nginx y sin querer, el usuario introduce el nombre de manera incorrecta, como "Nginc", se descargará la imagen maliciosa. La descarga

será exactamente igual que el contenedor real pero, además, tendrá algún contenido extra con intenciones maliciosas.

## Pasos del ataque:

1. Compromiso de una imagen maliciosa en Docker Hub o un repositorio privado.
2. Descarga e instalación de la imagen por parte de un usuario legítimo.
3. Ejecución del contenedor con código malicioso, obteniendo acceso a credenciales y sistemas.
4. Movimiento lateral dentro de la red, explotando vulnerabilidades.
5. Persistencia y exfiltración de datos: El atacante instala backdoors para mantener acceso prolongado.



## Métodos preventivos de ataques en cadena

Debido a lo mencionado en el apartado anterior, es necesario saber cómo mitigar o, mayormente, en este caso, evitar estos eventos nada deseables. Por ello, recomendamos las siguientes estrategias:



## Estrategias de prevención:

1. **Uso de imágenes verificadas:** Solo utilizar imágenes oficiales o firmadas digitalmente reduce el riesgo de incluir software malicioso.
2. **Registros privados y autenticación:** Limitar el acceso a registros de imágenes mediante autenticación y control de acceso impide modificaciones malintencionadas.
3. **Monitoreo y escaneo de vulnerabilidades:** Implementar herramientas de escaneo automatizado en la cadena CI/CD para detectar anomalías antes del despliegue.
4. **Principio de mínimos privilegios:** Configurar los contenedores para que operen con los privilegios mínimos necesarios reduce la superficie de ataque.
5. **Restricción de red y segmentación:** Implementar políticas de red que limiten la comunicación entre contenedores y eviten movimientos laterales no autorizados.
6. **Formación de Inteligencia en entornos de Docker:** Dentro de la empresa, formar a los trabajadores para que sean conscientes de estas posibilidades y que sepan cómo evitar y mitigar dichos sucesos.

Estas medidas ayudan a fortalecer la seguridad en entornos Docker y reducir la probabilidad de que un ataque en cadena comprometa sistemas críticos.

---

## Registro de Imágenes: ¿Qué es y cómo afecta a nuestro ataque?

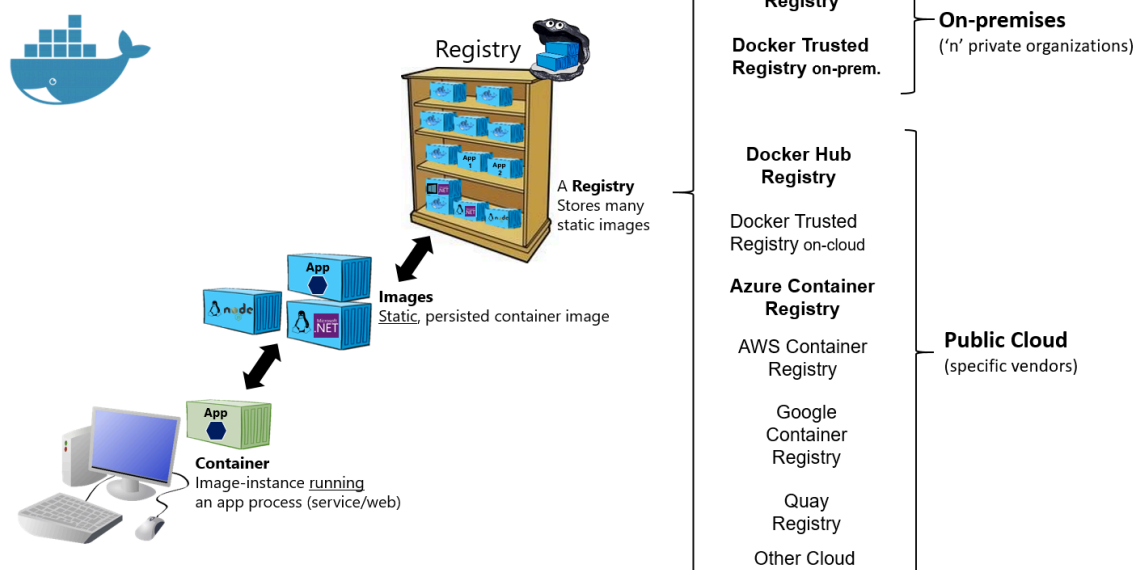
Los registros de imágenes son repositorios donde se almacenan y distribuyen imágenes de Docker. Existen registros públicos (como Docker Hub) y privados, utilizados dentro de organizaciones para mayor seguridad y control.

Un atacante puede comprometer un registro de imágenes de varias maneras:

- **Publicación de imágenes maliciosas:** Un atacante puede subir imágenes alteradas con malware o puertas traseras.
- **Secuestro de credenciales:** Si un usuario descarga imágenes comprometidas, sus credenciales pueden ser robadas.
- **Manipulación de imágenes oficiales:** Si un atacante tiene acceso al registro, puede modificar imágenes legítimas para incluir código malicioso.
- **Falta de verificación de integridad:** Si las imágenes no son firmadas o verificadas, se pueden ejecutar versiones alteradas sin que los usuarios lo noten.

Este tipo de ataques es fundamental en estrategias como el Ataque en Cadena, donde el atacante compromete un punto inicial y propaga la infección.

## Basic taxonomy in Docker



## **Conclusiones: ¿Qué hemos aprendido en este trabajo?**

Durante este trabajo, hemos profundizado en el funcionamiento de Docker y en los riesgos de seguridad asociados con su uso. Docker es una herramienta fundamental en el mundo del desarrollo y despliegue de aplicaciones, ya que permite la contenedorización de manera eficiente, escalable y portátil. Sin embargo, también hemos visto cómo una mala configuración o el uso de imágenes no verificadas pueden abrir la puerta a diversas amenazas de seguridad.

Uno de los aspectos más importantes que hemos aprendido es que la seguridad en Docker no se limita únicamente a proteger los contenedores, sino que también debe extenderse a los registros de imágenes, las políticas de acceso y la configuración de los sistemas subyacentes. Los atacantes pueden explotar vulnerabilidades en distintos niveles, como el uso de imágenes maliciosas, la escalada de privilegios o los ataques de denegación de servicio, poniendo en riesgo tanto la infraestructura como los datos sensibles de la empresa o del usuario.

También hemos estudiado el concepto de Ataque en Cadena, una técnica en la que los atacantes comprometen una pieza inicial del sistema, como una imagen de Docker modificada, y logran propagar la explotación a otros elementos de la infraestructura. Este tipo de ataques resaltan la importancia de verificar las imágenes antes de su ejecución, utilizar registros privados y aplicar mecanismos de control de seguridad para prevenir su propagación.

Para mejorar la seguridad en Docker, hemos identificado diversas prácticas recomendadas, cómo usar solo imágenes oficiales o verificadas, limitar los privilegios de los contenedores, monitorizar activamente los sistemas para detectar anomalías y configurar restricciones de recursos para evitar ataques de denegación de servicio. Además, es esencial integrar herramientas de escaneo de vulnerabilidades y políticas de red que reduzcan la exposición de los contenedores a posibles ataques.

En resumen, hemos aprendido que Docker es una herramienta muy potente, pero que, sin una gestión adecuada de la seguridad, puede convertirse en una puerta de entrada para diversos

tipos de amenazas. Adoptar buenas prácticas y herramientas de protección es fundamental para garantizar un uso seguro y eficiente de esta tecnología.

### Puntos clave aprendidos:

- Docker es una herramienta potente para la contenedorización, pero su seguridad depende de una correcta configuración y gestión.
- Los ataques pueden incluir imágenes maliciosas, escalada de privilegios, acceso no autorizado a registros de imágenes, ataques DoS y fugas de datos.
- La verificación de imágenes y el uso exclusivo de imágenes oficiales o de confianza son esenciales para evitar la instalación de código malicioso.
- Los contenedores no deben ejecutarse con privilegios elevados para evitar posibles escaladas de permisos.
- Los registros de imágenes deben estar protegidos mediante autenticación, firma digital y políticas de control de acceso.
- Los ataques de denegación de servicio pueden saturar los recursos del sistema si no se limitan correctamente los contenedores.
- La filtración de datos puede ser un riesgo grave si se dejan credenciales o información sensible dentro de los contenedores.
- La automatización de la seguridad mediante herramientas de monitorización y escaneo de vulnerabilidades es clave para prevenir ataques.
- La implementación de políticas de red y control de acceso puede reducir la exposición de los contenedores a amenazas externas.
- El **Ataque en Cadena** demuestra cómo un solo punto comprometido puede afectar a toda una infraestructura, subrayando la necesidad de una seguridad proactiva.
- Para garantizar un uso seguro de Docker, es fundamental adoptar buenas prácticas de seguridad y herramientas de protección continuas.